CorpNet SQL Injection

Challenge Walkthrough — SQL Injection

WEB FUNDAMENTALS · XE107 · SQL · CYBERIUM ARENA

Questions: 10 · Difficulty: Beginner · Author: Denis Albin

QUESTION 01 RECONNAISSANCE

Extract the lab zip using the password `infected` and run `bash start.sh` inside the extracted folder. Once the lab is running, open your browser and go to `http://localhost:8080`. What company name is shown at the top of the login page?

HOW TO SOLVE

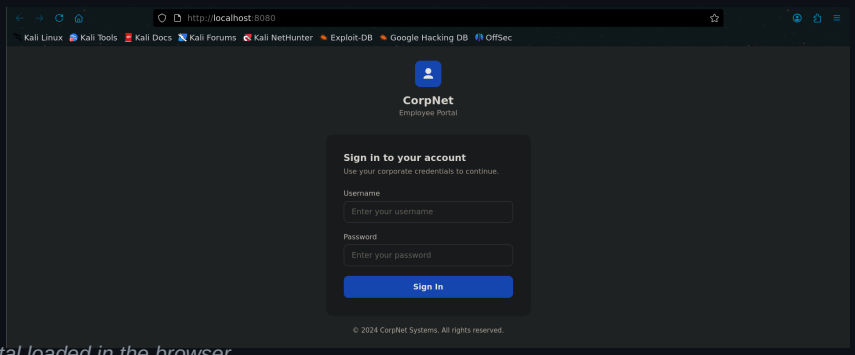
01 Extract the zip: `unzip -P infected htg-sqli.zip`

02 Navigate into the folder and run `bash start.sh`. Wait for 'Challenge is ready!'

03 Open your browser and go to `http://localhost:8080`.

04 Read the company name shown at the top of the page.

SCREENSHOTS



CorpNet Employee Portal loaded in the browser.

ANSWER

CorpNet

QUESTION 02 RECONNAISSANCE

Right-click anywhere on the login page and select View Page Source. Find the `<form>` tag in the HTML. What is the value of its `method` attribute?

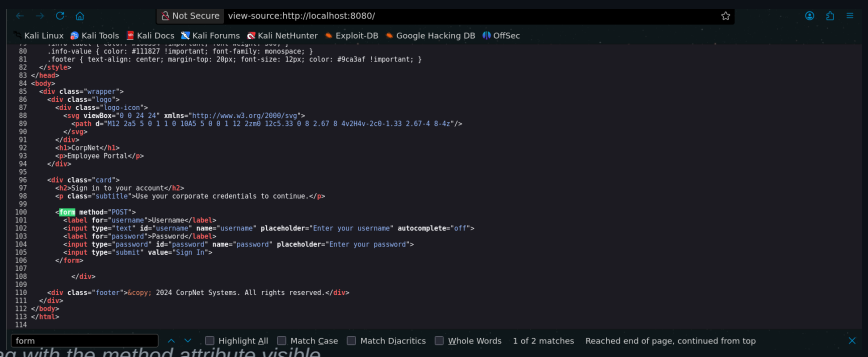
HOW TO SOLVE

01 Right-click anywhere on the page and select View Page Source.

02 Press `Ctrl+F` and search for `<form` to jump to the form element.

03 Find the `method` attribute on the form tag and read its value.

SCREENSHOTS



Page source — form tag with the method attribute visible.

ANSWER

POST

QUESTION 03 RECONNAISSANCE

On the login page, enter `admin` as the username and `wrongpassword` as the password, then click Sign In. What is the exact error message shown below the form?

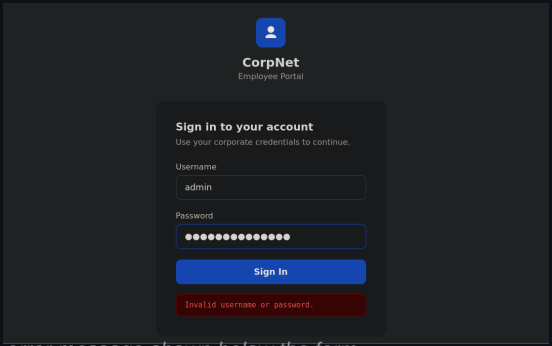
HOW TO SOLVE

01 Go to `http://localhost:8080` in your browser.

02 Enter `admin` in the Username field and `wrongpassword` in the Password field.

03 Click Sign In and read the exact message that appears in red below the form.

SCREENSHOTS



Login attempt with wrong credentials — error message shown below the form.

ANSWER

Invalid username or password.

QUESTION 04 EXPLOITATION

In the Username field, type a single quote ', leave the Password field blank, and click Sign In. What are the first two words of the error message returned?

HOW TO SOLVE

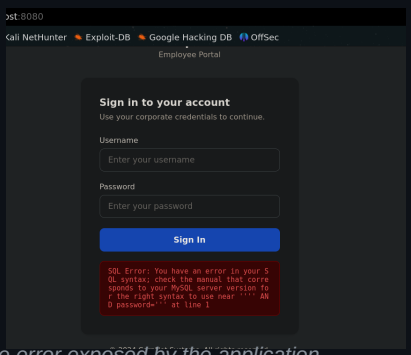
01 In the Username field, type a single quote character: '

02 Leave the Password field completely empty.

03 Click Sign In and read the first two words of the error shown in red.

04 This error confirms your input is being passed directly into a SQL query.

SCREENSHOTS



Single quote breaks the SQL query — database error exposed by the application.

ANSWER

SQL Error

QUESTION 05 EXPLOITATION

Look at the SQL error from Q4 — it shows the query ends with `AND password=''`. In MySQL, what single character placed after your username turns everything that follows into a comment, making the password check disappear?

HOW TO SOLVE

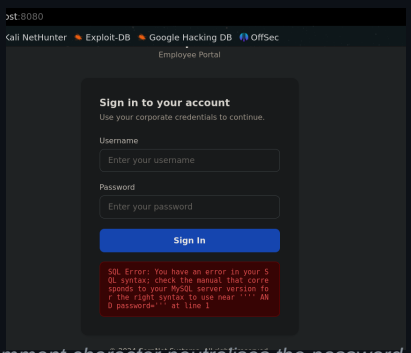
01 Read the full SQL error from Q4 — it reveals the query structure.

02 The query looks like: `WHERE username='[input]' AND password=''`

03 In MySQL, this character starts an inline comment — the database ignores everything after it on the same line.

04 It is a single character, not a word.

SCREENSHOTS



SQL error reveals the query structure — the comment character neutralises the password check.

ANSWER

#

QUESTION 06 EXPLOITATION

In the Username field, type `admin'#` and leave the Password field blank, then click Sign In. What is the Access Code shown on the dashboard after a successful login?

HOW TO SOLVE

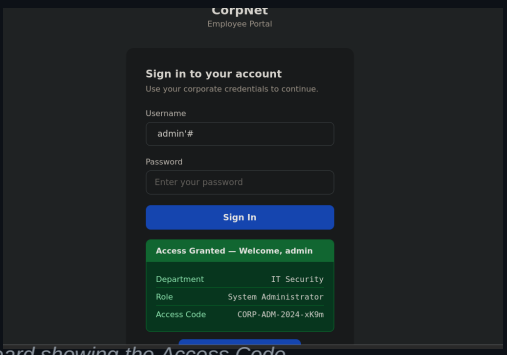
01 In the Username field, type: `admin'#`

02 Leave the Password field empty — the # comments out the password check.

03 Click Sign In. The database ignores the password and logs you in as admin.

04 Read the Access Code shown in the green dashboard panel.

SCREENSHOTS



Authentication bypassed — admin dashboard showing the Access Code.

ANSWER

CORP-ADM-2024-xK9m

QUESTION 07 EXPLOITATION

Click the Employee Directory button after logging in. The ID search field passes your input directly into a SQL query. Inject a payload that forces the database to return every employee record regardless of ID. How many employees are in the database?

HOW TO SOLVE

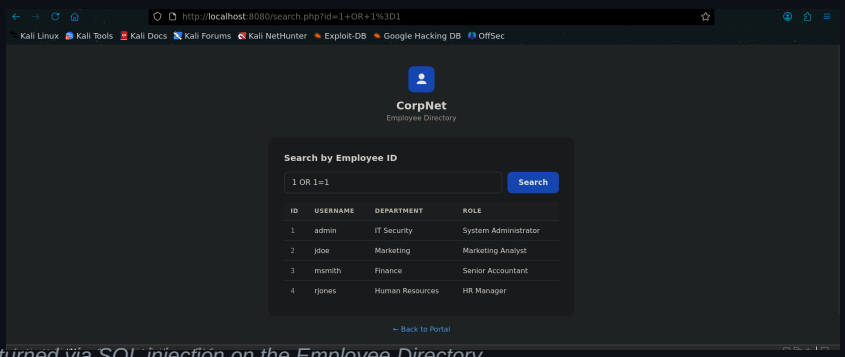
01 Click the Employee Directory button on the dashboard.

02 The ID field passes your input straight into a SQL query with no sanitisation.

03 Think of a SQL condition that is always true — inject it to make the database return all rows.

04 Count the number of employee records shown in the results table.

SCREENSHOTS



All employee records returned via SQL injection on the Employee Directory.

ANSWER

4

QUESTION 08 EXPLOITATION

Look at the employee records returned from Q7. What is the role of the employee with the username `rjones`?

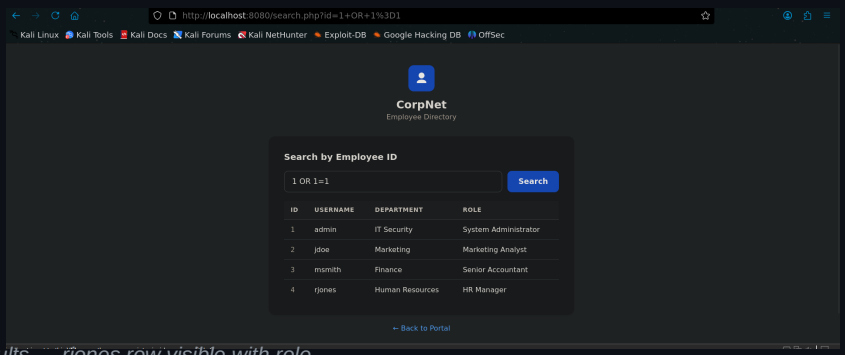
HOW TO SOLVE

01 The results table from Q7 is still visible.

02 Find the row where the username column shows `rjones`.

03 Read the value in the Role column for that row.

SCREENSHOTS



Employee Directory results — rjones row visible with role.

ANSWER

HR Manager

QUESTION 09 EXPLOITATION

Type `0 UNION SELECT 1,2,3,4--` in the ID field and click Search. The `0` returns no real records — only your injected row appears with numbers in each column. What number appears under the Department column?

HOW TO SOLVE

01 Clear the ID field and type: `0 UNION SELECT 1,2,3,4--`

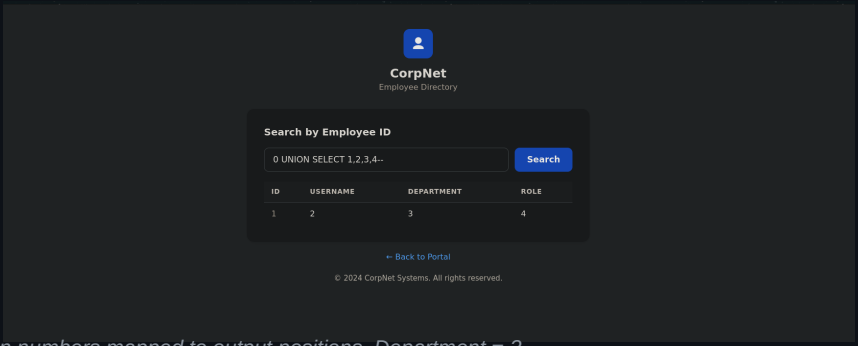
02 The `0` ensures no real rows are returned, only your injected one.

03 Click Search — one row appears with numbers filling each column.

04 The number under each column tells you its position. Read the value under Department.

05 You will use this position in Q10 to extract real data.

SCREENSHOTS



UNION probe — column numbers mapped to output positions. Department = 3.

ANSWER

3

QUESTION 10 EXPLOITATION

Replace the `3` in your payload with `password` and add `FROM users WHERE username='admin'` before the `--`. The admin's password will appear under the Department column. What is it?

HOW TO SOLVE

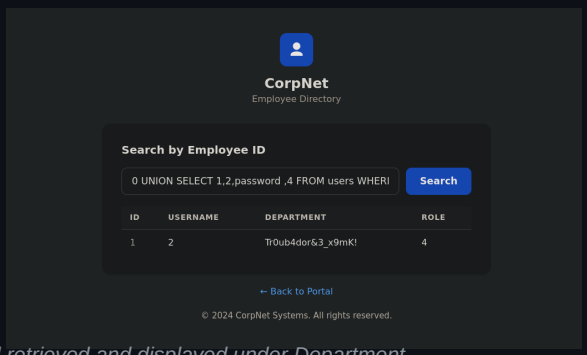
01 Take your payload from Q9: `0 UNION SELECT 1,2,3,4--`

02 Replace the `3` with `password` — this pulls the password column value.

03 Add `FROM users WHERE username='admin'` before the `--`.

04 Click Search and read the value shown under the Department column.

SCREENSHOTS



UNION extraction — admin password retrieved and displayed under Department.

ANSWER

Tr0ub4dor&3_x9mK!